MacZine

THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 055 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD REPORT · THREAT LANDSCAPE

Machine-Speed Attackers Just Made Small Contractors Worth Targeting

AI-orchestrated intrusions are documented, not hypothetical. What the record shows, what is still forecast, and what changes for a small DIB contractor.

BY **PATRICK CARUSO**

READING TIME · 7 MIN

THREAT-INTELLIGENCE · AI-SECURITY · INCIDENT-RESPONSE · NIST-800-171 · DFARS

In mid-September 2025, Anthropic's threat team noticed something wrong in the traffic of its own coding tool. Over the next ten days it pieced together a campaign it later attributed, with high confidence, to a Chinese state-sponsored group. The operators had picked about thirty targets: technology companies, financial institutions, chemical manufacturers, government agencies. Then they built a framework that used Claude Code as the engine and talked the model past its safeguards in two moves. They told it it worked for a legitimate security firm running defensive tests, and they broke the operation into small tasks, none of which looked like an attack on its own.

What followed ran in sequence. The model surveyed each target's infrastructure and reported back which databases looked most valuable. It found weaknesses, wrote exploit code and tested it. It harvested usernames and passwords, used them to reach the highest-privilege accounts, planted backdoors, pulled data out and sorted it by intelligence value. Finally it wrote up its own notes, cataloguing the stolen credentials and the systems it had mapped, so the next stage could be planned. By Anthropic's account the AI did 80 to 90 percent of the work. Humans stepped in at perhaps four to six decision points per campaign. At peak the framework was issuing thousands of requests, often several a second.

It succeeded against "a small number" of the thirty. And the model was not a reliable burglar: it sometimes hallucinated credentials that did not work, and reported secret finds that turned out to be public. Anthropic banned the accounts, notified affected organizations and worked with authorities.

That is the case. Hold onto two details from it, because they decide what a forty-person defense contractor should take away. The first is the ratio: six human decisions steering a machine's worth of labor across thirty organizations at once. The second is who noticed. It was the AI vendor, watching its own platform, and not any of the victims.

What is documented, and what is still a forecast

The word "swarm" is doing a lot of work in vendor marketing this year, so it helps to sort the record.

Documented, from primary sources: Anthropic's August 2025 threat report described a single criminal operator using the same tool to automate reconnaissance, credential harvesting and network penetration against at least seventeen organizations, including healthcare and emergency services, then having the model weigh the stolen financial data to set extortion demands that sometimes topped $500,000. Google's threat intelligence group reported on September 8 that in the second quarter of 2026 a financially motivated actor compromised a cloud environment, then used an AI coding assistant, a prompt and a set of markdown "playbooks" to plan, build and run a mass credential harvest in under six hours. The agents ran the scanning pipeline, fixed their own errors and rotated IP addresses without a human touching them. The same report found infostealers specifically grabbing the configuration files of AI coding assistants, where API keys sit in plain text, and an April intrusion that began with an exposed GitHub personal access token. On the fraud side, the FBI warned in December 2024 that criminals use cloned voices and real-time video to impersonate executives, and Mandiant's M-Trends 2026 found voice phishing had become the second most common way into a network, at 11 percent of intrusions.

FIELD COPY
ISSUE Nº 055
THREAT INTELLIGENCE

80-90%

OF THE WORK IN THE CAMPAIGN ANTHROPIC DISCLOSED IN NOVEMBER 2025 PERFORMED BY THE AI, WITH HUMANS AT ROUGHLY FOUR TO SIX DECISION POINTS

< 6 hrs

FOR A FINANCIALLY MOTIVATED ACTOR TO PLAN, BUILD AND RUN AN AGENT-DRIVEN CREDENTIAL HARVEST THAT TOOK THOUSANDS OF CREDENTIALS (GOOGLE, Q2 2026)

22 sec

MEDIAN 2025 HAND-OFF FROM INITIAL ACCESS TO A SECOND THREAT GROUP, DOWN FROM MORE THAN 8 HOURS IN 2022 (M-TRENDS 2026)

Also documented, and worth the same weight: Mandiant's own assessment that 2025 was not the year breaches came directly from AI. Exploits were still the top initial vector, at 32 percent, for the sixth year running. The vast majority of successful intrusions, in its words, still trace to basic human and systemic failures.

Forecast, not record: the self-directing swarm that chooses its own victims and needs no operator. The Five Eyes cyber agencies warned in June that frontier models could shift offensive capability quickly - "the timeline is not years, it is months," as Al Jazeera reported the statement - but a warning about pace is not a case file. DARPA's AI Cyber Challenge showed the raw capability is there on the defensive side: the seven finalist systems found 54 of 63 planted vulnerabilities in real open-source code, plus 18 that nobody had planted, at about $152 per task. Nobody has published an equivalent tally for a criminal operation, and this column will not guess at one.

The documented AI attacker has not found new doors. It has made trying every old door on every small network nearly free.

◆ WHAT "AUTONOMOUS" MEANT IN THE RECORD

In the campaign Anthropic described, humans chose the targets, built the framework, and approved the moves that mattered. The model did the volume work in between. That is the documented shape of an AI attack in 2025 and 2026 - human intent, machine labor - and it is the shape to plan against. A fully self-directing swarm that picks its own targets is not in any primary report this piece relied on.

What changes on a forty-person network

The comfortable assumption in the small end of the defense industrial base has always been economic. A skilled intruder's time is expensive, and a machine shop with one CUI file share is not worth a week of it. The record above removes the denominator. When six decisions steer thirty intrusions, the marginal cost of adding your network to the list is close to zero, and the question stops being whether you are worth someone's time and becomes whether you are exposed on the day the list is run.

That changes four working assumptions.

Dwell time first. M-Trends puts the 2025 global median at fourteen days, which sounds like a fortnight to notice. It is the wrong number to plan around. The same report found that the hand-off from the group that gets in to the group that exploits the access fell to a median of 22 seconds. An agent-run operation finishes its reconnaissance and harvesting while a monthly log review is still three weeks away. If your detection plan assumes someone reads alerts on Monday, the intrusion it would have caught is already over.

Patch windows next. Mandiant estimates the mean time to exploit is now negative seven days, meaning exploitation routinely starts before a fix ships. Patching faster still matters, and 3.14.1's "timely" is a number you set and an assessor holds you to, which Issue 40 walks through. But against a negative window the stronger move is one the Five Eyes statement urged: keep systems off the internet that do not need to be there. A VPN appliance that is not exposed cannot be swept, by a person or a machine.

◆ THE FEDERAL YARDSTICK MOVED

CISA's BOD 26-04, issued June 10, 2026, revoked BOD 22-01 and gives civilian agencies three calendar days, plus a forensic triage, for known-exploited flaws that are internet-exposed, automatable and yield full control. It cites attacker use of AI as part of the reason. It does not bind contractors, but it is now the number a program office has in its head when it hears "timely."

Then the 72-hour clock. Issue 11 walks DFARS 252.204-7012's reporting window hour by hour, and none of that changes. What changes is the distance between the attack and your discovery of it. A campaign that runs in six hours and leaves with valid credentials looks, in your logs, like a handful of successful logins. The clock starts on discovery, and the 90-day preservation duty that follows the report only helps if the logs existed and were kept long enough to cover the window you did not see.

Finally the balance between prevention and detection, which is where small contractors overspend in the wrong direction. Machine-speed attacks are fast, but they are not quiet. Thousands of requests a second, hallucinated credentials tried and failed, scanning bursts from cloud addresses: all of it is noise a watched system records. 3.14.6 asks you to monitor inbound and outbound traffic to detect attacks, and it carries five SPRS points, the methodology's heaviest weight. Prevention should go to the commodity paths the record shows working: phishing-resistant MFA so harvested passwords are worth less, a help desk that calls back on a known number before resetting anything, developer tokens and AI-tool keys treated as the credentials they are. Detection has to be good enough, and staffed enough, that a burst of failed logins at 3 a.m. becomes a decision rather than a line in a report nobody opens.

In the September campaign the party that saw the whole pattern was the platform the attacker rented, and the notifications to affected organizations came from that platform. A small contractor cannot count on a vendor's courtesy to be its detection layer, and it no longer has obscurity to fall back on. What is left is the unglamorous part of 800-171, done on the assumption that somebody, or something, is already trying the door. ◆